

SEGURANÇA DE REDES DE COMPUTADORES

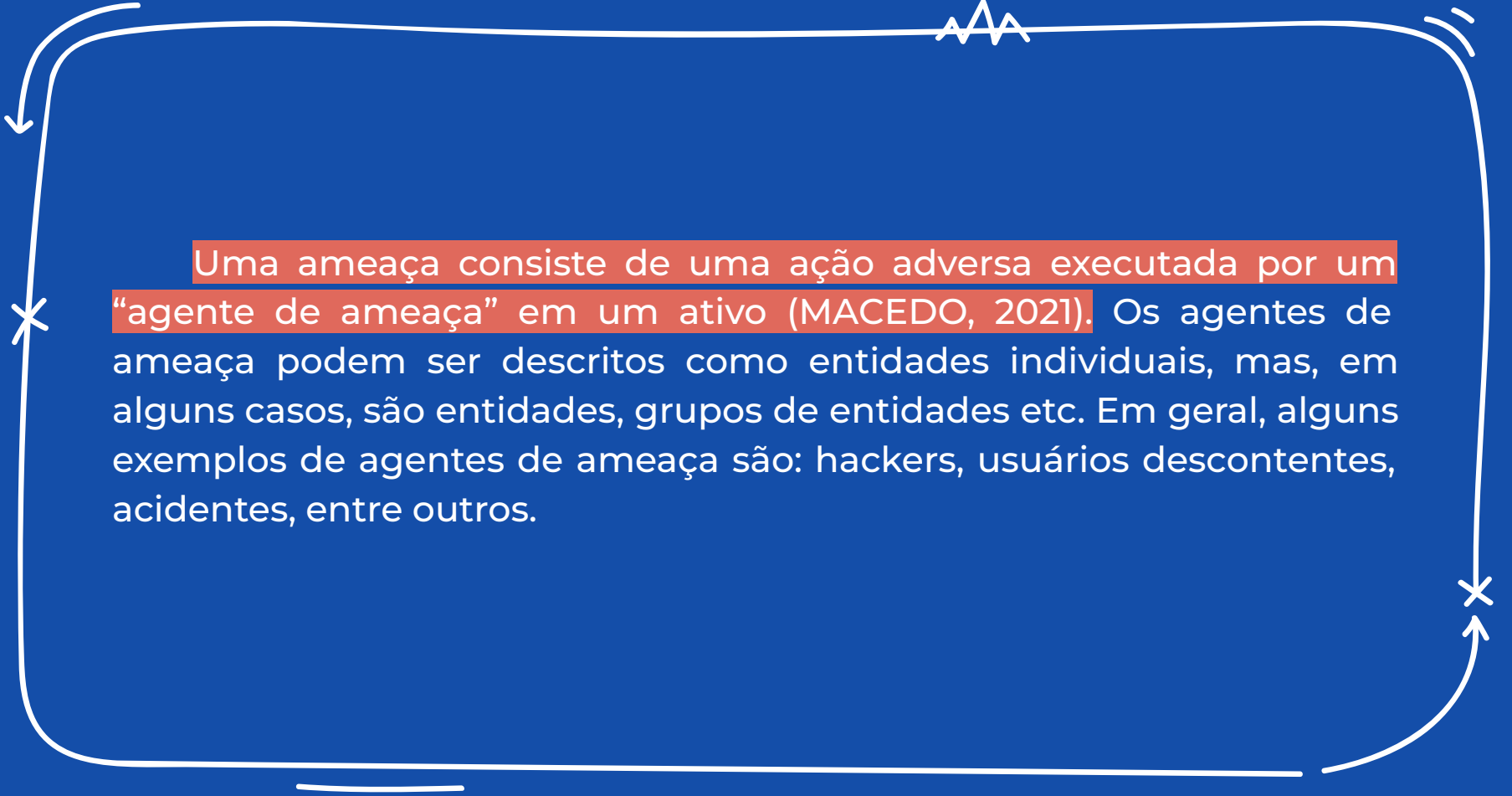


AMEAÇAS À SEGURANÇA



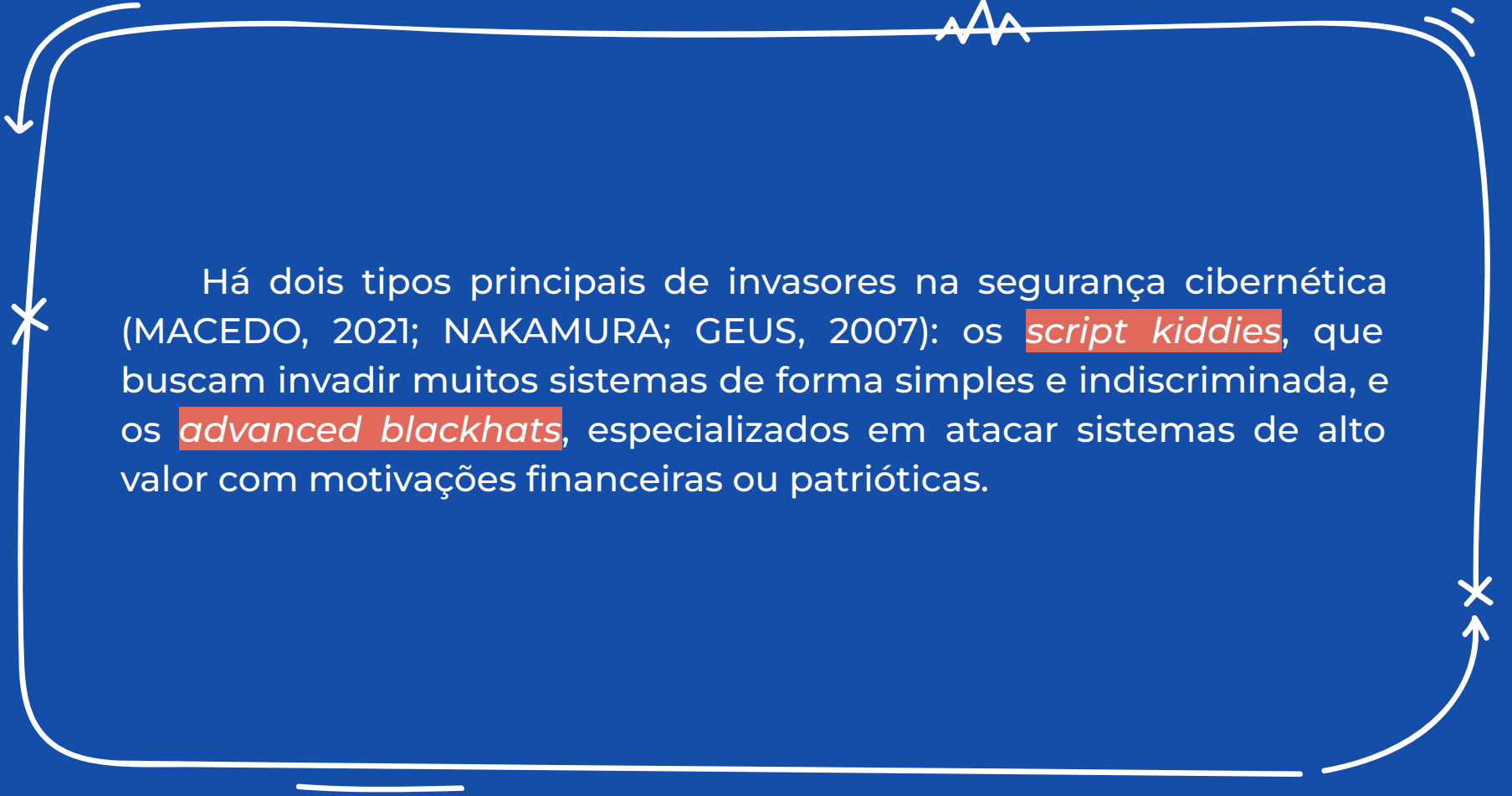
Ameaças à Segurança

Na área da segurança cibernética, o risco se refere ao resultado combinado das vulnerabilidades, ameaças e possíveis impactos de ataques cibernéticos. Uma vulnerabilidade representa uma possível falha no sistema de segurança da informação. Ameaça é uma possibilidade de ataque cibernético ao fazer uso de vulnerabilidades de um sistema (PRASAD; ROHOKALE, 2020).



Uma ameaça consiste de uma ação adversa executada por um “agente de ameaça” em um ativo (MACEDO, 2021). Os agentes de ameaça podem ser descritos como entidades individuais, mas, em alguns casos, são entidades, grupos de entidades etc. Em geral, alguns exemplos de agentes de ameaça são: hackers, usuários descontentes, acidentes, entre outros.

Para compreender o conceito de ameaça, é essencial analisar inicialmente o agente do problema, ou seja, o invasor. Ao entender a identidade e os métodos de operação da ameaça, torna-se mais claro o valor e a utilidade das precauções de segurança. Além disso, o tipo de invasor que se busca identificar, rastrear ou neutralizar influenciará diretamente o desenho e a implementação das medidas de segurança necessárias.



Há dois tipos principais de invasores na segurança cibernética (MACEDO, 2021; NAKAMURA; GEUS, 2007): os *script kiddies*, que buscam invadir muitos sistemas de forma simples e indiscriminada, e os *advanced blackhats*, especializados em atacar sistemas de alto valor com motivações financeiras ou patrióticas.

Os *script kiddies* são mais numerosos e menos sofisticados, enquanto os *advanced blackhats* são menos comuns, altamente habilidosos e difíceis de rastrear devido à sua discrição. Além destes ainda há, os *Cyberpunks, Insiders, Coders, White Hat* e *Gray Hat* (NAKAMURA; GEUS, 2007).

A evolução contínua de ataques direcionados e avançados, acompanhada de ameaças persistentes, demanda o desenvolvimento de técnicas robustas de segurança cibernética, com abordagens inovadoras.

Diversas categorias de ataques cibernéticos incluem malwares, ataques de rede, intrusões em redes, ataques em redes sociais, engenharia social, espionagem cibernética, acesso não autorizado a redes, ciberespionagem, terrorismo digital, e guerra cibernética.

Categoria	Descrição de ataque	Subataques
Malware	Software malicioso usado para lançar ataques específicos nos sistemas dos computadores.	<i>Adware, Spyware, Virus, Worm, Trojan, Rootkit, Backdoors, Key loggers, Rogue Security Software, Ransomware, Browser Hijacker etc.</i>
Ataque de rede	Monitoramento ativo ou passivo de comunicações de computador e tráfego de rede.	<i>Passivo, Ativo, Distribuído, Insider, Closein, Phishing, Hijacking, Spoofing, Buffer overflow, Exploit, ataque de senhas (força bruta) etc.</i>
Ataques de intrusão de rede	Qualquer atividade não autorizada em redes de computadores	<i>Asymmetric routing, Buffer overflow, Protocol specific attacks, Traffic flooding, Trojans, Worms etc.</i>
Engenharia social	Usando redes sociais ou por telefone, os invasores aplicam truques de psicologia para os usuários fornecerem informações sigilosas.	<i>Phishing, Pre-texting, Baiting, Quid Pro Quo, Tailgating etc.</i>

Espionagem Cibernética	Espionagem de informações confidenciais de um usuário ou organização sem permissão	Espionagem industrial, Espionagem do Estado-nação, Espionagem econômica, Espionagem corporativa, Roubo de informações e sabotagem.
Reconhecimento	Ao descobrir os pontos fracos em sistemas de rede e serviços, o atacante reúne informações sensíveis sobre a rede.	Busca de informações na Internet, Varredura de <i>ping</i> , varredura de porta, <i>Packet sniffers</i> .
Ataques de Acesso à rede	Através de pesquisas maliciosas na rede de atividades de: autenticação, FTP e <i>web services</i> , o intruso obtém acesso a um sistema de rede para obter informações confidenciais.	<i>Eavesdropping, Data modification, Identity spoofing, Password-based, Denial of service, man in the middle attack, Compromised key attack, Sniffer attack, Application layer Attack, Trust exploitation etc.</i>
Terrorismo cibernético	Uso da internet para atividades terroristas eletrônicas, como perturbação em grande escala de redes de computadores, infraestruturas críticas nacionais ou importantes operações de negócio.	Sabotagem, desfiguração de site e negação de serviço, Destruição de infraestruturas físicas críticas etc.
Guerra cibernética	Grande perturbação em escala nacional e global, com ataques a importantes infraestruturas críticas, que afetam a vida de milhares de pessoas.	

Crime cibernético

Utiliza tecnologias de computador para realizar atividades criminosas, principalmente através de ataques cibernéticos. Estes consistem em tentativas ilegítimas de obter informações, dinheiro ou outros benefícios, e podem ser classificados como baseados na web ou em sistemas.

Além disso, existem três outros tipos de ataques cibernéticos considerados por alguns especialistas: ataques naturais, causados por erros humanos, e provenientes de ameaças internas ou externas, como hackers e criminosos cibernéticos. Este tópico aborda diversos tipos de ataques cibernéticos, incluindo backdoors, Ataque DoS, espionagem, falsificação, adulteração, ataque de repúdio, engenharia social, malware, adware, entre outros;

Backdoors

Técnica maliciosa que visa criar um acesso não autorizado e muitas vezes persistente a um sistema de computação, permitindo ao invasor contornar as políticas de segurança e realizar atividades prejudiciais no sistema comprometido. Nesse ataque, o invasor instala software de registro de chaves ou qualquer outro software, por meio do qual obtém acesso ao sistema das vítimas;

Ataques de negação de serviço

(*Denial-of-service*)

Têm o objetivo de tornar um recurso computacional indisponível. Durante esse ataque, o atacante sobrecarrega o sistema, impedindo que o usuário legítimo acesse dados ou recursos – resultando na inibição dos serviços do sistema. Normalmente, um único dispositivo ou conexão de internet é usado para atacar o servidor-alvo, sobrecarregando seus recursos, como largura de banda, buffers de conexão TCP, buffer de aplicativo/serviço e ciclos de CPU.

Uma variante mais potente é o Ataque Distribuído de Negação de Serviço (DDoS), que envolve muitos dispositivos e um grande número de conexões de internet para atacar vários servidores simultaneamente, causando uma paralisação completa. Este tipo de ataque pode ser parte de um Botnet, comprometendo milhares de servidores em um curto período de tempo;

Eavesdropping (Espionagem)

O atacante intercede na comunicação do sistema ou rede sem detecção, empregando essa comunicação para um segundo invasor ou adversário daquela organização.

Este é um tipo de ataque passivo, em que o observador simplesmente monitora e adquire informações que estão sendo transmitidas por computadores, smartphones ou outros dispositivos de rede. Em seguida, ele colabora em ataques ativos, ao fornecer todas as informações necessárias sobre a rede. Redes Wi-Fi públicas representam os alvos mais acessíveis para esse tipo de espionagem, pois qualquer pessoa pode ingressar na rede e facilmente obter a senha disponível;

Spoofing (falsificação)

Envolve o invasor ou um programa agindo como se fosse o usuário genuíno e autorizado de um sistema ou rede. Ao fazer isso, oculta sua verdadeira identidade e assume a posição de administrador do sistema ou da vítima. Geralmente, essas ameaças têm origem em e-mails, nos quais o endereço IP do remetente é falsificado. Ao se apropriar e utilizar a identidade de outra pessoa, o invasor monitora o tráfego de rede e registra informações para obter acesso aos nomes de usuário e senhas dos usuários da rede.

Existem três tipos possíveis de ataques de spoofing, incluindo spoofing de ARP, spoofing de IP e Falsificação de DNS. A falsificação de IP é utilizada em ataques de negação de serviço (DoS) e em ataques do tipo *man in the Middle*;

Tampering (Adulteração)

Tipo de ataque web em que o invasor manipula certos parâmetros na URL de um site sem o conhecimento do usuário. A URL aparenta ser autêntica aos olhos do usuário. Os hackers realizam essas alterações para obter acesso não autorizado ao sistema ou a algo potencialmente valioso. Ao obter acesso ilegal, certos parâmetros inseridos pelo usuário em uma página web específica são capturados e modificados. Durante a troca de informações entre o cliente e o servidor, o atacante interfere de forma manipulativa;

Ataque de repúdio

Ataque no qual um usuário nega falsamente ter realizado alguma atividade ou participado de uma transação eletrônica. Quando um usuário nega a execução de determinadas ações ou operações, isso é chamado de repúdio. Esse usuário pode ser tanto legítimo quanto um agente mal-intencionado.

Se o aplicativo ou sistema não possui os devidos controles para rastrear as ações registradas do usuário, o hacker tem a oportunidade de manipular as informações em trânsito. É crucial ter um mecanismo de defesa robusto que seja capaz de monitorar e manter um registro de todas as atividades dos usuários. O ataque de repúdio mais comum é a falsificação de mensagens de e-mail;

Engenharia Social

Tipo de ataque não técnico, que se baseia no comportamento humano. Consiste em enganar o usuário e obter informações úteis dele. O atacante induz o usuário a revelar suas informações secretas, quebrando assim o processo normal de segurança. Esses ataques incluem isca, phishing, spear phishing, pretextos e scareware;

Adware

Semelhante ao malware, pois usa anúncios para infectar computadores com vírus mortais. Janelas pop-up aparecem continuamente na tela, onde o usuário está trabalhando. Geralmente, adware malicioso entra no sistema com programas e utilitários de software gratuitos baixado da Internet;

Ransomware

Ameaça na qual os invasores restringem o acesso do usuário aos recursos do sistema e, em seguida, solicitam um pagamento para remover essa restrição. Esse resgate é efetuado online por meio de métodos de pagamento, como bitcoin, que não podem ser rastreados. Após o pagamento, o usuário pode recuperar o acesso ao serviço. Sistemas bloqueados com um ransomware simples podem ser desbloqueados com a assistência de um especialista em segurança. No entanto, o ataque de ransomware avançado criptografa arquivos críticos no sistema da vítima e requer um pagamento para descriptografar e liberar os arquivos;

Spyware

Funciona como um agente secreto. O principal objetivo dos Spywares é reunir as informações com o uso da Internet e sem conhecimento do usuário. O spyware pode ser encontrado em um software livre, que está disponível gratuitamente na Internet para todos. Quando a vítima instala software gratuito, o spyware também é instalado no back-end por meio do qual o invasor obtém as informações do sistema da vítima;

Phishing

Tática de fraude online que visa obter informações confidenciais, como senhas e dados bancários, ao criar uma cópia idêntica de um site legítimo. A vítima, ao interagir com a página falsa, inadvertidamente fornece seus dados ao invasor. Esse método é frequentemente perpetrado por meio de e-mails falsificados;

Ataques de Senha

(Ataque de força bruta)

Realizado quando um invasor quer saber a senha da vítima. Um invasor pode adivinhar a senha ou criar um programa que pode adivinhar a senha no sistema pelo método de força bruta, ou usa um banco de dados que contém um conjunto de senhas comuns e experimenta no sistema;

Footprinting

Processo de fazer um mapa da rede ou sistema de uma organização. No início, um invasor deve escolher um sistema de destino, aplicativo ou localização física;

Malware

Software projetado para introduzir ações indesejadas no sistema pretendido (PRASAD; ROHOKALE, 2020), causando muitos prejuízos. Existem vários tipos de malware, desde: vírus, worms, cavalos de Troia etc.;

Vírus e Worms

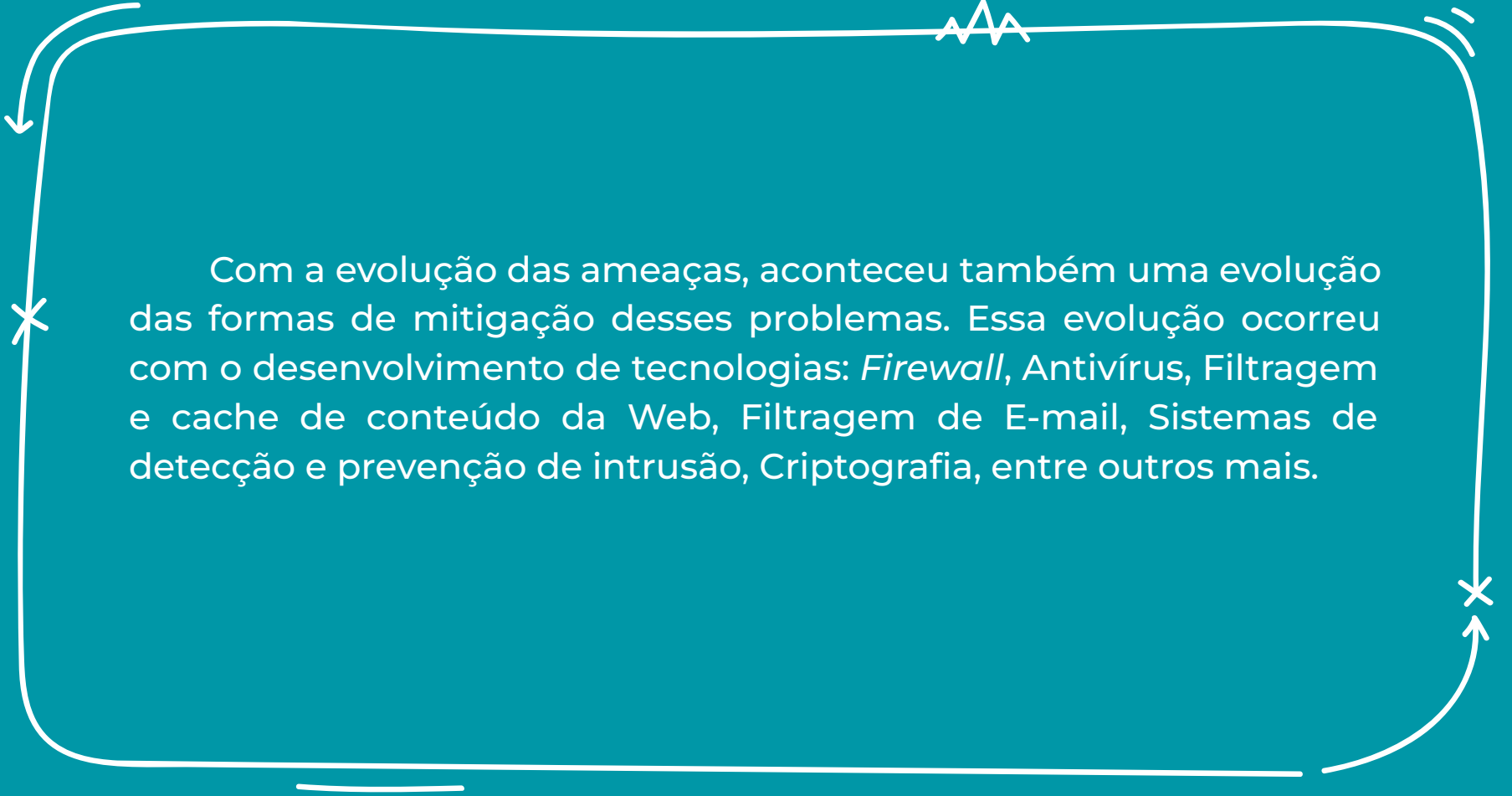
Usados para infectar ou modificar o conteúdo do sistema, a fim de facilitar que atacantes possam ter acesso aos computadores. Eles são responsáveis por espalhar a infecção em grande escala, pois se replicam. Os worms têm capacidade de autorreplicação e podem se espalhar rapidamente de sistema para sistema;

Bot e Botnet

BOTs são programas autônomos que imitam a inteligência humana e podem ser utilizados para postar SPAM em páginas web automaticamente. Ataques remotos são viabilizados por meio de BOTs. Uma BOTNET é um conjunto de máquinas robóticas infectadas, usadas principalmente para perpetrar ataques DDoS, enviar SPAM em massa, criar esquemas de marketing fraudulentos, roubar informações. Com uma BOTNET, é possível infectar ou paralisar grandes redes de computadores em questão de segundos;

Cavalos de Troia (*Trojans*)

Programas maliciosos que operam de maneira clandestina, realizando uma avaliação abrangente e possibilitando o controle do computador ou sistema. Diferentemente de um vírus real, o cavalo de Troia não se reproduz, mantendo a vítima alheia ao ataque. Geralmente, os cavalos de Troia estão dissimulados em anexos de e-mail ou em programas como jogos. Os ataques associados a cavalos de Troia incluem *Backdoors* ou *Trojans* de acesso remoto (RATs), kits de exploração, rootkits, cavalos de Troia de *ransomware*, entre outros.



Com a evolução das ameaças, aconteceu também uma evolução das formas de mitigação desses problemas. Essa evolução ocorreu com o desenvolvimento de tecnologias: *Firewall*, Antivírus, Filtragem e cache de conteúdo da Web, Filtragem de E-mail, Sistemas de detecção e prevenção de intrusão, Criptografia, entre outros mais.

O **Firewall** é um mecanismo para gerenciar e controlar o tráfego que ingressa e sai das redes. Geralmente, os firewalls são implantados em pontos onde ocorrem transições no nível de confiança, como na fronteira entre uma rede interna e a Internet (MACEDO, 2021). Além disso, é possível instalar um firewall na rede interna com o objetivo de prevenir acessos não autorizados ao tráfego de dados de natureza sensível.

Os **Sistemas de Detecção e Prevenção de Intrusão (IDPSs)** operam de forma semelhante a um sistema de alarme antirroubo. Quando o sistema identifica uma violação - como uma janela aberta ou quebrada - aciona o alarme. Este alarme pode ser tanto audível e visível (por meio de ruídos e luzes), quanto silencioso, enviando uma mensagem para uma empresa de monitoramento. Como é comum em quase todos os IDPSs, os administradores têm a opção de configurar os níveis de alerta.

Muitos IDPSs também podem ser ajustados para notificar os administradores por e-mail. Sistemas que incorporam tecnologia de prevenção de intrusão buscam evitar o sucesso do ataque por meio de uma das seguintes abordagens:

1. interrompendo o ataque;
2. alterando o ambiente de segurança;
3. modificando o conteúdo do ataque para torná-lo inofensivo.

Referências

BEAL, A. Segurança da informação: princípios e melhores práticas para a proteção dos ativos de informação nas organizações. [s.l.] São Paulo: Atlas, 2008.

CARUSO, C. A. A.; STEFFEN, F. DENY. Segurança em informática e de informações. 4. ed. [s.l.] Senac São Paulo, 2006.

FERREIRA, F. N. F.; ARAÚJO, M. T. DE. Política de segurança da informação guia prático para elaboração e implementação. 2. ed. Rio de Janeiro: Ciência Moderna, 2008.

FIPS PUB 199. Standards for Security Categorization of Federal Information and Information Systems. 2004. [s.l: s.n.]. Disponível em: <<https://csrc.nist.gov/pubs/fips/199/final>>.

FOINA, P. ROGÉRIO. Tecnologia De Informação: Planejamento E Gestão. 3. ed. [s.l.] Atlas, 2013.

FRANCISCATTO, R.; DE CRISTO, F.; PERLIN, T. Redes de Computadores. Frederico Westphalen: UFSM, 2014.

GROSS, C. M.; GROSS, J. C. Segurança em Tecnologia da informação. [s.l.] UNIASSELVI, 2013.

GUTTMAN, B.; ROBACK, E. An Introduction to Computer Security: the NIST Handbook. Special Publication (NIST SP), National Institute of Standards and Technology, Gaithersburg, MD, out. 1995.

KLUSAITĖ, L. A história da segurança cibernética. 2022. Disponível em: <<https://nordvpn.com/pt-br/blog/historia-seguranca-cibernetica/>>.

MACEDO, M. Introdução à Segurança da Informação Corporativa. Pernambuco: 2021 [s.n.].

NAKAMURA, E. T.; GEUS, P. L. Segurança de Redes em Ambientes Cooperativos. [s.l.] Novatec, 2007.

NBR ISO/IEC 17799. Tecnologia da informação - Código de prática para a gestão da segurança da informação. Rio de Janeiro, ABNT, 2001.

PRASAD, R.; ROHOKALE, V. Cyber Security: The Lifeline of Information and Communication Technology. Cham: Springer International Publishing, 2020.

WHITMAN, M. E.; MATTORD, H. J. Management of Information Security. 4. ed. [s.l.] Cengage Learning, 2013.

Professor Autor

Evandro Luis da Rosa

Professora Revisora

Taís Belzarena

Designer Instrucional

Ricardo Andrade Lopes

Design Gráfico

Helena Dias

Ilustrações

Adobe Stock

Envato Elements

Flaticon

Freepik

Storyset

Proibida a reprodução total ou parcial, sem autorização.
Lei de Direitos Autorais nº 9610/98.